Software Requirements Specification

for

Anora - Mental Wellness App

Version 1.0 approved

Prepared by
Aaryan Singh - 10281
Sherlynn Vaz - 10286
Dev Tripati - 10285

TE COMPS B, Fr. CRCE

2nd February, 2026

Table of Contents

Table of Contents ii
Revision History ii
1. Introduction 1
1.1 Purpose 1
1.2 Document Conventions 1
1.3 Intended Audience and Reading Suggestions 1
1.4 Product Scope 1
1.5 References 1
2. Overall Description 2
2.1 Product Perspective 2
2.2 Product Functions 2
2.3 User Classes and Characteristics 2
2.4 Operating Environment 2
2.5 Design and Implementation Constraints 2
2.6 User Documentation 2
2.7 Assumptions and Dependencies 3
3. External Interface Requirements 3
3.1 User Interfaces 3
3.2 Hardware Interfaces 3
3.3 Software Interfaces 3
3.4 Communications Interfaces 3
4. System Features 4
4.1 System Feature 1 4
4.2 System Feature 2 (and so on) 4
5. Other Nonfunctional Requirements 4
5.1 Performance Requirements 4
5.2 Safety Requirements 5
5.3 Security Requirements 5
5.4 Software Quality Attributes 5
5.5 Business Rules 5
6. Other Requirements 5
Appendix A: Glossary 5
Appendix B: Analysis Models 5
Appendix C: To Be Determined List 6

1. Introduction

1.1 Purpose

The purpose of this document is to define the functional and non-functional requirements for **Anora**, a mobile application designed to bridge the gap between mental wellness tracking and data privacy. The system utilizes a **Zero-Knowledge Architecture** to ensure that sensitive journal entries and emotional insights remain mathematically inaccessible to the service provider, utilizing on-device AI for analysis

1.2 Document Conventions

Typographical Conventions

- **Boldface** is used for significant terms, section headers, and emphasis on critical constraints (e.g., **Zero-Knowledge**, **Local-First**).
- Italics are used for referenced documents and citations of specific external standards (e.g., IEEE Standard 830, GDPR).

Requirement Naming Standards Functional and Non-Functional requirements are indexed using the following alphanumeric tags to facilitate traceability:

- **FR-X.Y:** Functional Requirements (e.g., **FR1.1.2** for encryption standards).
- **PR-X:** Performance Requirements (e.g., latency limits).
- **DC-X:** Design Constraints (e.g., "Zero-Knowledge" architecture rules).

Prioritization Scheme Requirements in this document follow a strict hierarchy based on the project's "Security First" prioritization criteria. In cases of conflict between requirements, the following precedence applies:

1. **Level 1 (Critical): Security & Privacy.** Features related to encryption (AES-256), authentication, and the "Privacy Vault" take precedence over all other functionality.
2. **Level 2 (High): Core Utility.** Basic journaling stability and local database integrity must be ensured before advanced analytics.
3. **Level 3 (Medium): Analytics & AI.** On-device inference and mood tracking features.
4. **Level 4 (Low): Connectivity & Polish.** Cloud sync, UI theming, and resource portals.

Project-Specific Terminology

- The term **"User"** refers strictly to the patient/journaler, whereas **"Clinician"** refers to the medical professional receiving reports.
- **"Local-First"** implies that a feature must be fully functional offline, with network activity being secondary.

1.3 Intended Audience and Reading Suggestions

Intended Audience This Software Requirements Specification (SRS) is intended for the following primary stakeholders:

- **Development Team (Mobile & Backend):** Developers responsible for implementing the Flutter mobile application, the Python/FastAPI "Blind Mailman" backend, and the local SQLite/Hive database integration.
- **AI/ML Engineers:** Personnel tasked with training, quantizing, and integrating the MentalBERT model (TFLite) and implementing the Federated Learning protocols.
- **Security & Cryptography Specialists:** Auditors responsible for verifying the "Zero-Knowledge" architecture, "Privacy Guard" firewall, and the AES-256/RSA-2048 encryption implementations.
- **Quality Assurance (QA) Team:** Testers creating test cases for UI performance, AI inference latency (<200ms), and security penetration testing.
- **Clinical Consultants:** Medical professionals reviewing the application's alignment with DSM-5 requirements and the utility of the "Locked Box" clinician reports.

Reading Suggestions This document is organized to facilitate quick access to relevant information based on stakeholder roles:

- **Project Managers & Stakeholders:** Should focus on **Section 2 (Overall Description)** to understand the "Local-First" product perspective, user characteristics, and the general constraints regarding hardware and connectivity.
- **Developers & Engineers:** Should proceed directly to **Section 3 (Specific Requirements)**.
    - Mobile Developers should focus on the Functional Requirements for the Secure Journaling System (Section 3.2.1) and On-Device AI (Section 3.2.2).
    - Backend Developers should focus on the "Blind Mailman" API specifications and Federated Learning integration (Section 3.2.4).
- **Security Auditors:** Are advised to pay strict attention to **Section 3.2.3 (Clinician Reporting)** and **Section 3.4 (Design Constraints)**, which detail the cryptographic key exchanges and privacy guard protocols.
- **Clinical Consultants:** Should review **Section 1.1 (Purpose)** and **Section 2.2 (Product Functions)** to verify that the wellness tracking and reporting features meet patient care standards.

1.4 Product Scope

Anora is a privacy-first mental wellness application designed to bridge the gap between personal self-reflection and professional clinical care. The software functions as a secure, local-first journaling platform that utilizes on-device Artificial Intelligence (MentalBERT) to provide users with real-time emotional analysis and risk detection without transmitting raw data to the cloud.

The primary objectives and scope of the Anora system include:

- **Zero-Knowledge Privacy:** Ensuring that all raw journal entries and Protected Health Information (PHI) are encrypted locally (AES-256) and never leave the user's device in an intelligible format.
- **Clinical-Grade Insights:** Providing users with immediate feedback on emotional trends and DSM-5 aligned risk indicators (e.g., anxiety, depression) to foster self-management.
- **Secure Clinician Reporting:** Facilitating the secure transfer of derived insights to healthcare providers via a "Locked Box" cryptographic protocol, allowing for data-driven therapy sessions without compromising patient trust.

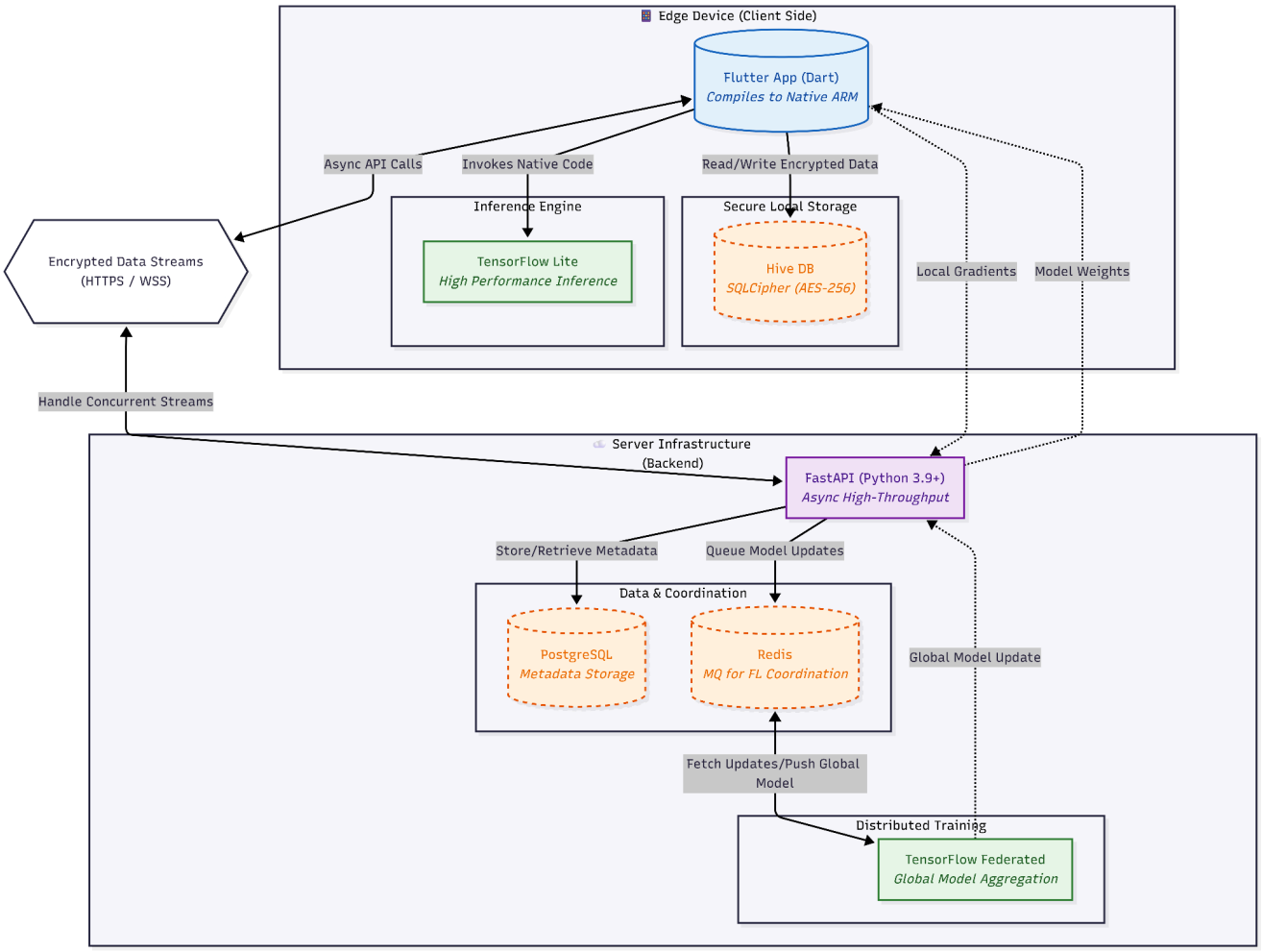
- **Decentralized Model Improvement:** Implementing Federated Learning to refine the AI's predictive capabilities collaboratively across the user base without centralizing sensitive training data.

This software aligns with the strategic goal of creating a "Zero-Knowledge" ecosystem where mental health support is accessible, accurate, and completely private.

1.5 References

- *Suruliraj, Banuchitra & Orji, Rita. (2022). Federated Learning Framework for Mobile Sensing Apps in Mental Health. 1-7. 10.1109/SEGAH54908.2022.9978600.*
- *A. Gupta et al., "Privacy-Preserving Hybrid Federated Learning Framework for Mental Healthcare Applications: Clustered and Quantum Approaches," in IEEE Access, vol. 12, pp. 1-1, 2024.*
- *Shaoxiong Ji, Tianlin Zhang, Luna Ansari, Jie Fu, Prayag Tiwari, and Erik Cambria. 2022. MentalBERT: Publicly Available Pretrained Language Models for Mental Healthcare. In Proceedings of the Thirteenth Language Resources and Evaluation Conference, pages 7184–7190, Marseille, France. European Language Resources Association.*

2. Overall Description

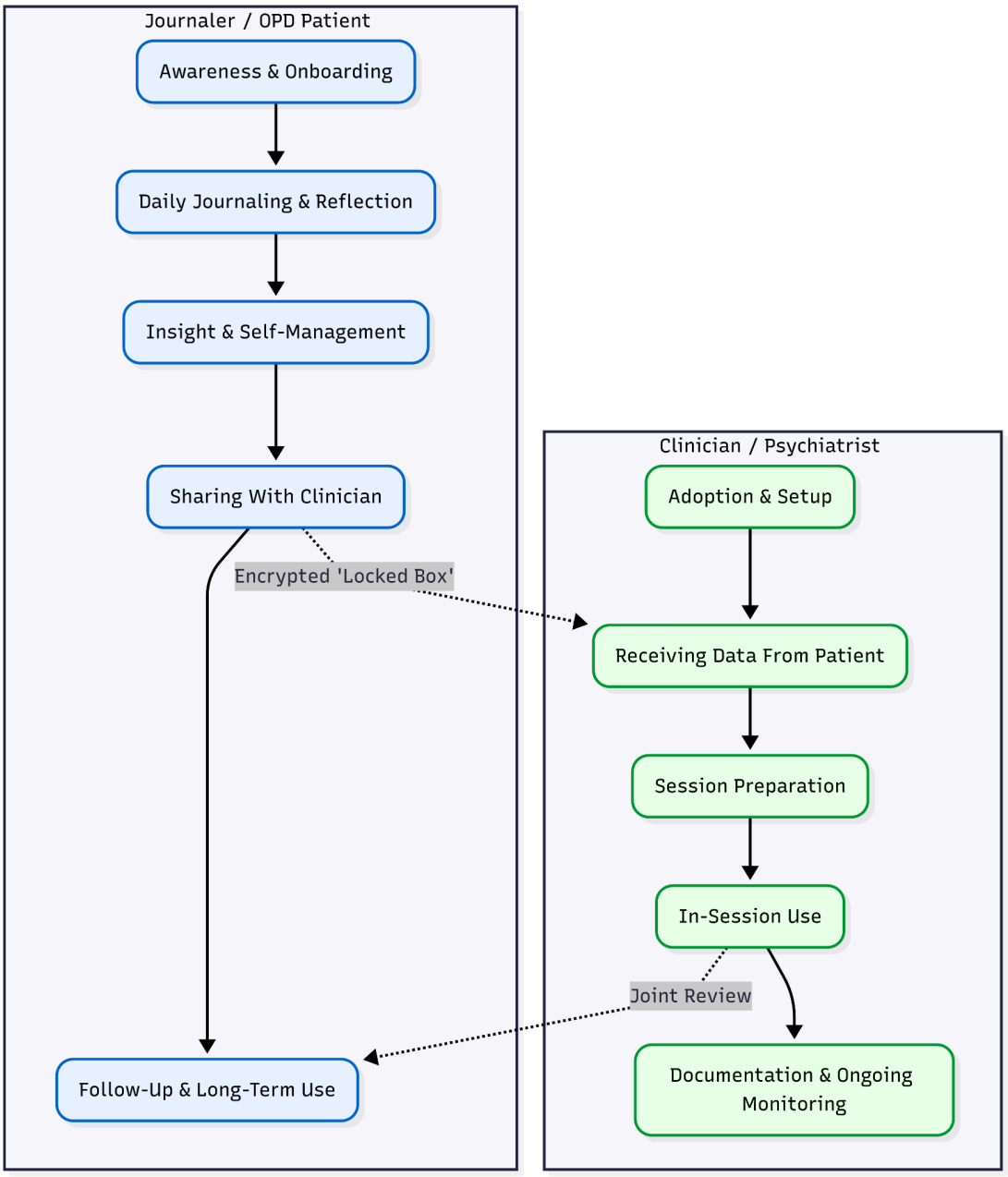


2.1 Product Perspective

Anora operates as a new, self-contained "Local-First" mobile application with a supporting, yet minimized, backend infrastructure. Unlike traditional client-server wellness apps, Anora processes all primary logic and data storage on the client device.

- **System Interfaces:** The mobile app acts as the primary interface for data ingestion and inference. The backend server functions strictly as a "Blind Mailman" for routing encrypted reports and as a Coordinator for Federated Learning (FL).
- **Independence:** The software is designed to function independently of the backend for core features (journaling, analysis). Connectivity is only required for optional clinician reporting and model updates.
- **Hardware Interfaces:** The system interacts directly with the mobile device's Neural Processing Unit (NPU) for accelerated TFLite inference and the Secure Enclave/Keystore for hardware-backed encryption key management.

2.2 Product Functions



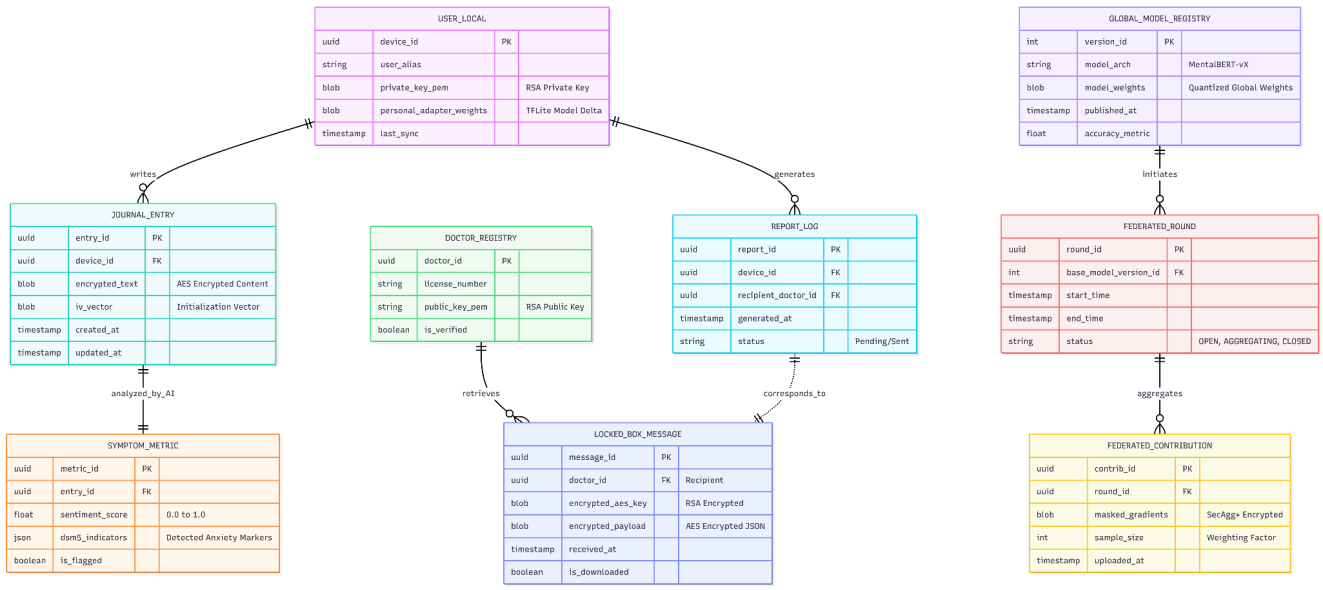
The major functions of the Anora system include:

- **Secure Journaling:** Creation and local storage of journal entries encrypted via AES-256-GCM.
- **On-Device AI Analysis:** Real-time inference using a quantized MentalBERT model to detect emotional states (7 classes) and risk flags (e.g., Self-Harm, Anxiety).
- **Clinician "Locked Box":** Generation of a cryptographically secure export (Hybrid Encryption) allowing users to share summaries with providers without the server accessing the raw data.
- **Federated Learning:** Computation of local model gradients and secure transmission of masked updates to improve the global AI model.
- **Insight Dashboard:** Visualization of mood trends, risk patterns, and sleep/anxiety correlations.

2.3 User Classes and Characteristics

The system identifies two distinct user classes, differentiated by their access levels and functional needs:

- **Patient (Journaler) - Primary User Class**
  - **Role:** The individual generating the data.
  - **Characteristics:** Likely privacy-conscious, seeking mental wellness support, with varying degrees of technical expertise.
  - **Privileges:** Full ownership of data, control over encryption keys, and exclusive rights to initiate data sharing.
- **Clinician (Psychiatrist/Therapist) - Secondary User Class**
  - **Role:** The professional recipient of data.
  - **Characteristics:** Time-constrained professionals requiring high-level summaries rather than raw logs.
  - **Privileges:** Limited to decrypting specifically shared reports using a private key and viewing aggregated clinical dashboards.



2.4 Operating Environment

The software will operate in the following environment:

- **Client Devices:** Smartphones running Android (API Level 26+) or iOS (Version 14+).
- **Hardware Platform:** ARM64 processors capable of running TensorFlow Lite delegates.
- **Backend Server:** Dockerized environment hosting Python (FastAPI), PostgreSQL (Metadata), and Redis (Message Queue).
- **Coexistence:** The app must peacefully coexist with standard OS background processes and battery optimization protocols.

2.5 Design and Implementation Constraints

The following constraints limit the development options:

- **Zero-Knowledge Privacy:** A strictly enforced policy where no raw user text is ever transmitted to or stored on external servers.
- **Hardware Limitations:** The on-device AI model (MentalBERT) must be quantized to INT8 and strictly limited to under 50MB to ensure storage efficiency.
- **Timing Requirements:** Inference operations must complete in under 200ms to maintain UI responsiveness.
- **Battery Constraints:** Federated Learning background tasks must be constrained to run only when the device is idle and connected to a power source.

2.6 User Documentation

The following documentation components will be delivered with the software:

- **In-App Onboarding:** An interactive tutorial explaining the "Local-First" privacy model and encryption setup.
- **Clinician Setup Guide:** A PDF manual detailing the generation of RSA keypairs and the process for decrypting patient reports.
- **Privacy Whitepaper:** A publicly accessible technical document explaining the data lifecycle and security guarantees.

2.7 Assumptions and Dependencies

Device Security (Assumption): It is assumed that the user's device is secured with a PIN, Pattern, or Biometric lock, as the app relies on the OS Secure Enclave to protect encryption keys.

Clinician Key Management (Assumption): It is assumed clinicians will manage their Private Keys securely; there is no central key recovery mechanism if a key is lost.

Third-Party Components (Dependency): The system relies on TensorFlow Lite and TensorFlow Federated; changes or deprecations in these libraries may impact the maintenance of the AI pipeline.

3. External Interface Requirements

3. External Interface Requirements

3.1 User Interfaces

The user interface is designed with a "Local-First" philosophy, ensuring all primary interactions function without internet connectivity.

- General Design: The application must utilize a "soothing" UI theme to promote mental wellness.
- Dashboard Components:
    - Mood/Risk Dashboard: Displays visual analytics, including mood trends and sleep alignment graphs, derived from local analysis.
    - Privacy Vault: A distinct, locked section of the UI accessible only via biometric authentication for highly sensitive entries.

    - Clinician Dashboard: A separate web-based interface for clinicians to decrypt and view "Locked Box" reports.
- Safety Constraints: The interface must never display raw text data in unsecured views or transmission logs.

3.2 Hardware Interfaces

- Biometric Sensors: The software interfaces with the device's native biometric hardware (Fingerprint/FaceID) to authenticate users and unlock the "Privacy Vault".
- Secure Enclave: The application interacts with the device's hardware-backed KeyStore/Secure Enclave to store encryption keys safely.
- Processor (NPU/CPU): The software directly interfaces with the mobile processor to run the TFLite inference engine, requiring optimization for low-end devices.

3.3 Software Interfaces

- Database: The application connects to a local SQLite or Hive database for persistent storage of encrypted journal entries.
- Inference Engine: The system integrates TensorFlow Lite (TFLite) to execute the quantized MentalBERT model for on-device emotion analysis.
- Backend API: The application interfaces with the "Blind Mailman" backend (built on Python/FastAPI) to route encrypted data blobs.
- Encryption Libraries: The system utilizes standard cryptographic libraries (e.g., flutter_secure_storage) for AES-256 and RSA implementations.

3.4 Communications Interfaces

- Protocols: All communications use HTTPS to ensure transport security.
- Privacy Guard Firewall: A network interceptor layer acts as an internal firewall, blocking any HTTP request that contains raw text strings.
- Data Formatting:
    - Reports: Encrypted as binary blobs using a hybrid AES/RSA scheme.
    - Federated Learning: Model gradients are masked using the Secure Aggregation (SecAgg) protocol before transmission.
- Security: Strict certificate pinning is enforced to prevent Man-in-the-Middle (MitM) attacks during key exchange.

4. System Features

4.1 System Feature 1: Secure Journaling & Storage

4.1.1 Description and Priority

- Description: The core capability allowing users to create diary entries that are immediately encrypted and stored locally. This is the foundation of the "Zero-Knowledge" architecture.
- Priority: High (Critical Foundation).

4.1.2 Stimulus/Response Sequences

- *Stimulus:* User opens the app and successfully authenticates via biometrics.
- *Response:* System decrypts the local database key from the Secure Enclave and loads the UI.
- *Stimulus:* User types a journal entry and taps "Save."

- *Response:* System immediately encrypts the text with AES-256 and saves the ciphertext to the local SQLite database.

4.1.3 Functional Requirements

- REQ-1: The system must allow users to create text-based journal entries.
- REQ-2: All journal entries must be encrypted using AES-256 before being committed to the local database.
- REQ-3: The system must ensure no raw text is ever transmitted to a cloud server.
- REQ-4: The system must provide a "Privacy Vault" feature for locking highly sensitive entries behind an additional authentication layer.

4.2 System Feature 2: On-Device AI Analysis

4.1.1 Description and Priority

- Description: Real-time analysis of journal entries using a local AI model to detect emotional trends and risk flags without sending data to the cloud.
- Priority: High (Core Value Proposition).

4.1.2 Stimulus/Response Sequences

- *Stimulus:* User saves a new journal entry.
- *Response:* The TFLite engine processes the text locally using the quantized MentalBERT model.
- *Response:* The system outputs a mood score and checks for risk flags (e.g., "Anxiety").
- *Response:* The Dashboard updates the mood trend graph; if a risk is detected, a local alert is logged.

4.1.3 Functional Requirements

- REQ-5: The system must utilize a quantized MentalBERT model to perform real-time emotion analysis.
- REQ-6: The inference latency must be less than 200ms per entry.
- REQ-7: The platform must detect risk flags (Self-harm, Anxiety, Depression) locally without internet access.
- REQ-8: The system must display derived analytics (mood trends) without exposing the underlying raw text data.

4.3 System Feature 3: Clinician "Locked Box" Reporting

4.1.1 Description and Priority

- Description: A secure mechanism for users to share summarized insights with their doctors. The data is encrypted specifically for the clinician, ensuring the server (Anora) cannot read it.
- Priority: Medium (Spiral 3 Feature).

4.1.2 Stimulus/Response Sequences

- *Stimulus:* User selects "Generate Report" and selects a clinician.
- *Response:* System fetches the clinician's Public RSA Key.
- *Response:* System aggregates insights, encrypts them with a one-time AES key, and encrypts that key with the RSA Public Key.
- *Response:* The encrypted blob is uploaded via the "Blind Mailman" API.

4.1.3 Functional Requirements

- REQ-9: Users must be able to generate a "Locked Box" export containing a summary of insights.

- REQ-10: The export must be encrypted using a one-time AES key, which is then encrypted with the clinician's public RSA-2048 key.
- REQ-11: The backend must route these encrypted packages without having the capability to decrypt them ("Blind Mailman" architecture).

4.4 System Feature 4: Federated Learning Integration

4.1.1 Description and Priority

- Description: A background process that improves the AI model by learning from user data locally and sharing only mathematical updates (gradients), not text.
- Priority: Medium/Low (Optimization Phase).

4.1.2 Stimulus/Response Sequences

- *Stimulus:* Device enters "Idle" and "Charging" state.
- *Response:* System calculates model gradients based on recent local data.
- *Response:* System masks gradients using Secure Aggregation (SecAgg).
- *Response:* Masked gradients are sent to the server for global model updates.

4.1.3 Functional Requirements

- REQ-12: The system must calculate model gradients locally during device idle time.
- REQ-13: The platform must mask these gradients using Secure Aggregation (SecAgg) before transmission.
- REQ-14: The system must integrate these updates to improve the model over time without collecting user data.

5. Other Nonfunctional Requirements

5.1 Performance Requirements

Performance is critical due to the "Local-First" architecture which relies on mobile hardware for AI inference.

- PR-1 (Inference Latency): The AI inference engine (TFLite) must complete the analysis of a journal entry in less than 200ms to prevent UI blocking.
- PR-2 (Model Size): The quantized MentalBERT model must not exceed 100MB to ensure compatibility with standard mobile device memory limits.
- PR-3 (App Size): The total application package size (APK/IPA) should be optimized to remain under 50MB to facilitate easy download and updates.
- PR-4 (Database Performance): Local database queries (SQLite/Hive) must retrieve encrypted entries with a decryption delay of less than 50ms per entry to ensure smooth scrolling in the journal list.

5.2 Safety Requirements

Since Anora deals with sensitive mental health data, safety mechanisms are required to prevent harm.

- SR-1 (Data Loss Warning): The application must explicitly warn users during onboarding and settings access that "If you lose your device, data is lost" due to the absence of server-side keys.
- SR-2 (Risk Detection Fallback): If the AI detects a high-risk flag (e.g., "Self-harm"), the system must immediately present a non-intrusive safety resource card (e.g., helpline numbers) regardless of internet connectivity.

- SR-3 (Fail-Safe Storage): In the event of a crash during a write operation, the database must maintain Atomicity (ACID properties) to prevent corruption of the encrypted journal file.

5.3 Security Requirements

Security is the primary feature of Anora, enforcing the "Zero-Knowledge" and "Blind Mailman" paradigms.

- SecR-1 (Encryption Standard): All local data must be encrypted at rest using AES-256.
- SecR-2 (Key Management): Encryption keys must be generated on-device and stored exclusively in the device's Secure Enclave (iOS) or KeyStore (Android).
- SecR-3 (Transport Security): All data in transit (reports, gradients) must be encrypted over HTTPS, with strict certificate pinning to prevent Man-in-the-Middle (MitM) attacks.
- SecR-4 (Privacy Guard): A "Privacy Guard" firewall layer must be implemented to block any outgoing HTTP request that contains raw text strings from the journal.
- SecR-5 (Locked Box Protocol): Clinician reports must be encrypted using a hybrid scheme: AES for the data payload, and RSA-2048 for the key exchange, ensuring only the intended clinician can decrypt it.

5.4 Software Quality Attributes

- Reliability: The "Risk Detection" module must be 100% available offline, ensuring critical safety checks function without a network connection.
- Usability: The UI must be "soothing" and aesthetically pleasing to encourage consistent usage, as verified by user feedback during Iteration 2.
- Maintainability: The codebase must follow a modular architecture (e.g., separating the UI, Crypto, and AI logic) to allow for independent updates, such as swapping the AI model without rewriting the app.
- Portability: The application uses Flutter to ensure cross-platform compatibility (Android & iOS) from a single codebase.

5.5 Business Rules

- BR-1 (Clinician Access): Only clinicians with a verified RSA Public Key can receive "Locked Box" reports; the system must reject exports to unverified recipients.
- BR-2 (Zero-Knowledge Compliance): No employee or developer of Anora shall have access to decryption keys or raw user data under any circumstances.
- BR-3 (Model Updates): The global AI model shall only be updated via Federated Learning aggregates (SecAgg) and never via direct data collection.

6. Other Requirements

6.1 Database Requirements

The system requires a robust local database solution to support its "Local-First" architecture.

- **Local Persistence:** The application must utilize **SQLite** or **Hive** for local data storage.
- **Encrypted Storage:** All database files must be encrypted at rest. The database schema must support the storage of encrypted binary blobs (ciphertext) for journal entries, rather than plain text fields.
- **Data Separation:** The database design must logically separate "User Identity" data (keys, settings) from "Journal Content" to facilitate secure wiping of sensitive data without resetting app preferences.

- **ACID Compliance:** The database must support Atomicity, Consistency, Isolation, and Durability (ACID) transactions to ensure that no partial entries are saved in case of an app crash or battery failure.

6.2 Legal & Compliance Requirements

Given the sensitive nature of mental health data, the system must adhere to strict legal and ethical standards.

- **GDPR & HIPAA Alignment:** The "Zero-Knowledge" architecture is designed to meet the privacy constraints of **GDPR** (General Data Protection Regulation) and **HIPAA** (Health Insurance Portability and Accountability Act) by ensuring that the service provider (Anora) never possesses the technical means to access patient data.
- **DSM-5 Alignment:** The AI analysis and risk detection algorithms must be aligned with **DSM-5** (Diagnostic and Statistical Manual of Mental Disorders) criteria to ensure clinical relevance and accuracy in risk flagging.
- **Data Ownership:** The Terms of Service must explicitly state that the user retains full ownership of their data. The system must provide a "Nuke" option allowing the user to permanently delete all local and server-side (encrypted) data instantly.

6.3 Reuse Objectives

The project aims to build reusable components for future privacy-focused applications.

- **Modular Cryptography:** The "Locked Box" encryption module (hybrid AES/RSA) should be developed as a standalone library or package to be reused in other healthcare applications requiring secure reporting.
- **Blind Mailman API:** The backend API logic for routing encrypted blobs without decryption should be containerized and documented to serve as a template for other "Zero-Knowledge" services.

6.4 Internationalization Requirements

- **Date/Time Localization:** Journal entries must be timestamped and displayed according to the user's local device settings (e.g., DD/MM/YYYY vs. MM/DD/YYYY) to prevent confusion in tracking mood trends over time.
- **Language Support:** While the initial release focuses on English (due to the MentalBERT model), the UI architecture should support localization strings (.arb files in Flutter) to allow for future translations without code changes.

6.5 Deployment & Distribution

- **Containerization:** The backend services (Blind Mailman API) must be Dockerized to ensure consistent deployment across different server environments.
- **App Store Compliance:** The mobile application must adhere to the specific "Health & Fitness" category guidelines of the Apple App Store and Google Play Store, particularly regarding the declaration of data collection (or lack thereof).

6.6 Testing Requirements

- **Penetration Testing:** Rigorous security testing must be performed specifically on the "Blind Mailman" backend and the "Privacy Guard" firewall to attempt to leak raw text.
- **Model Validation:** The quantized AI model must be tested against standard datasets to ensure that the quantization process (INT8) has not degraded accuracy below acceptable clinical thresholds.

Appendix A: Glossary

This glossary defines the specific terms, acronyms, and abbreviations used throughout the Anora

Software Requirements Specification.

- ***AES-256:*** *Advanced Encryption Standard (256-bit). A symmetric encryption algorithm used by Anora to secure local database files.*
- ***Anora:*** *The name of the privacy-first mental wellness tracking application described in this document.*
- ***Blind Mailman:*** *A backend architectural pattern where the server routes encrypted data blobs between users and clinicians without possessing the decryption keys.*
- ***Clinician:*** *A medical professional authorized by the user to receive and decrypt "Locked Box" reports.*
- ***DSM-5:*** *Diagnostic and Statistical Manual of Mental Disorders (5th Edition). The standard classification of mental disorders used to align Anora's risk detection algorithms.*
- ***Federated Learning (FL):*** *A machine learning technique where the model is trained across multiple decentralized edge devices (phones) holding local data samples, without exchanging them.*
- ***Flutter:*** *The open-source UI software development kit used to build the Anora mobile application.*
- ***Hive/SQLite:*** *The local database technologies used for storing encrypted journal entries on the user's device.*
- ***Locked Box:*** *A reporting feature where user insights are encrypted specifically for a clinician using their public RSA key.*
- ***MentalBERT:*** *The pre-trained Natural Language Processing (NLP) model used for on-device emotion analysis and risk detection.*
- ***Privacy Guard:*** *A network interceptor layer within the application that blocks any HTTP request containing raw text strings.*
- ***Quantization:*** *The process of reducing the precision of the AI model (e.g., from float32 to INT8) to reduce its size and latency for mobile use.*
- ***RSA-2048:*** *A public-key cryptosystem used for secure key exchange between the user and the clinician.*
- ***SecAgg (Secure Aggregation):*** *A protocol used to mask model gradients before they are sent to the server, ensuring individual updates cannot be reverse-engineered.*
- ***TFLite (TensorFlow Lite):*** *The lightweight AI inference engine used to run the MentalBERT model on mobile devices.*
- ***Zero-Knowledge:*** *A security concept ensuring that the service provider (Anora) stores user data but has no technical ability to access or decrypt it.*

Appendix B: Analysis Models

This section outlines the software development lifecycle models and architectural diagrams used to guide the development of Anora.

B.1 Software Development Lifecycle Models

Anora utilizes a hybrid approach combining Spiral, Incremental, and Waterfall models to manage risk

and delivery.

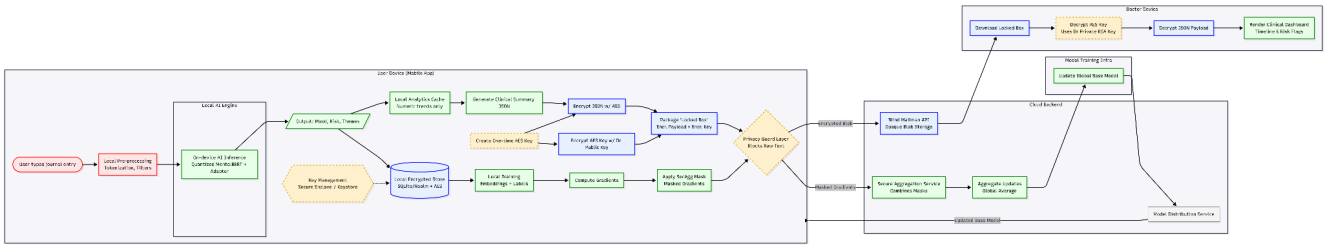
1. Spiral Model (Risk Management) Used to manage high-risk components like encryption lag and AI model size.

- ***Spiral 1 (Basic Privacy):*** *Focuses on "Zero-Knowledge" storage and AES-256 implementation. Risk: Encryption causing UI lag .*
- ***Spiral 2 (Intelligent Insights):*** *Focuses on on-device AI inference. Risk: Model size exceeding 100MB. Mitigation: Quantization.*
- ***Spiral 3 (Connected Ecosystem):*** *Focuses on "Locked Box" sharing and Federated Learning. Risk: Man-in-the-Middle attacks.*

2. Incremental Model (Delivery Strategy) Used to break down development into manageable deliverables.

- ***Increment 1:*** *Core Flutter UI + SQLite + AES-256.*
- ***Increment 2:*** *TFLite Inference Engine + MentalBERT.*
- ***Increment 3:*** *Privacy Guard + Analytics Dashboard.*
- ***Increment 4:*** *"Locked Box" Cryptography (RSA).*
- ***Increment 5:*** *"Blind Mailman" Backend (Python/FastAPI).*
- ***Increment 6:*** *Federated Learning Clients.*
- ***Increment 7:*** *Clinician Dashboard.*

B.2 System Architecture Diagrams



- ***Data Journey Diagram (Red/Green/Blue Classification):***
  - ***Red Data (Raw Text):*** *Never leaves the device. Blocked by "Privacy Guard".*
  - ***Green Data (Encrypted Blobs):*** *Allowed to travel to the "Blind Mailman" backend for storage/sync.*
  - ***Blue Data (Gradients):*** *Masked numerical updates sent to the Federated Learning server.*
- ***Local-First Architecture:***
  - ***Client:*** *Flutter App containing UI, Local DB, and TFLite Model.*
  - ***Boundary:*** *"Privacy Guard" Firewall.*
  - ***Server:*** *Python Container (Blind Mailman) + Federated Aggregator.*

Appendix C: To Be Determined (TBD) List

The following items are currently undefined or require further clarification to be closed.

TBD ID	***Description***	***Impact Area***
TBD-01	***Cloud Sync Implementation:*** *The documents state "data is lost if device is lost" , but also mention "Cloud Sync". The specific protocol for encrypted cloud backup (vs. strictly local storage) needs to be defined.*	*Storage / Architecture*
TBD-02	***Wellness Content Source:*** *The source of "curated articles and meditation techniques" is undefined. It is TBD whether this is hardcoded, fetched from a CMS, or third-party API.*	*Content / Backend*
TBD-03	***Minimum Hardware Specs:*** *"Low-end devices" is mentioned, but exact minimum RAM and Android/iOS version requirements for running the quantized MentalBERT model are not yet benchmarked.*	*Performance / Testing*
TBD-04	***Clinician Verification:*** *The specific mechanism for verifying a clinician's identity before they can generate a Public RSA Key is TBD.*	*Security / Business Rules*